

AI Audit Report — HW06 API Testing (§9, phụ lục bắt buộc)

- **Sinh viên:** Lê Nhựt Duy — **MSSV:** 23127178
- **AI Policy của bài:** Open — **bắt buộc** có lời khai + audit đầy đủ. §17: thiếu tài liệu bắt buộc = 0 điểm.

I use AI tools for the following tasks.

Công cụ đã dùng (§8)

Công cụ	Việc
Claude Code (Opus 5)	chọn API, sinh test case, audit, viết collection Postman, tooling, báo cáo
Postman + Newman	thực thi test case, xuất HTML report
(bổ sung nếu dùng thêm)	

Cách đọc file này

Mỗi lượt hỏi AI = một mục `Interaction #N`, ghi đủ 5 trường §9 (tool · ngày giờ · prompt nguyên văn · output · human review) cộng 3 trường riêng của HW06 (bước trong quy trình · AI sai/bỏ sót · vì sao bỏ sót). Ba trường sau chép thẳng được sang §11 của `report/main-report.md`.

Trường **Human review** ghi **ai kiểm gì** — không viết gộp thành "đã kiểm hết":

- **(SV đã kiểm)** — sinh viên tự chạy lại / đối chiếu spec / đối chiếu source, kèm **ngày và phạm vi**. Có ở 5 lượt: #3, #6, #7, #9, #11.
- **Ghi theo dữ kiện** — mỗi lượt ghi rõ *sinh viên đã tự làm gì và phần nào do AI soát, bằng phép kiểm nào*. Không viết gộp thành "đã kiểm hết", và cũng không ghi "SV đã đọc" ở chỗ chưa có bằng chứng: §11 phạt đúng loại bằng chứng dựng, còn AI Policy của bài là **Open** nên ghi đúng ai làm gì là đủ.

Phần soát tài liệu do AI thực hiện, và số liệu của nó nằm ở đây để người chấm tự đánh giá: 4 lượt soát tìm được **1 → 3 → 2 → 2** lỗi (không lượt nào về 0), tất cả đã sửa và mỗi loại lỗi được chuyển thành một **phép kiểm bằng máy** để không tái diễn: mọi con số công bố, mọi link nội bộ, mọi hash commit, mọi nhãn audit, mọi danh sách case đỏ đều được đối chiếu với dữ liệu thật ở **mỗi lần** chạy `npm run verify` (38 mục, 0 lỗi).

Interaction #1

- **API / Bước:** chọn API cho 3 pool (trước §6.1)
- **Bước trong quy trình:** chọn phạm vi — §5
- **AI tool:** Claude Code (Opus 5)

- **Date & time:** 2026-08-18 23:17
- **Prompt:** (ảnh chụp 4 bộ API các bạn đã chọn) + "những cái trên là cái api mà bạn tui nó chọn. bạn hãy dựa vào yêu cầu đề bài chọn cho tui các api khác đi" + file đề 2026.HW06.API Testing_En.pdf
- **AI output (tóm tắt):** đọc đề + api_specification.md + backend/server.js, đối chiếu 4 bộ API đã bị lấy, đề xuất bộ 3 chưa ai chọn: GET /api/products (A/FR-05) · POST /api/cart (B/FR-07) · PUT /api/products/:id (C/FR-15), kèm giả thuyết bug rút từ source (SQL nối chuỗi ở :143, không validate ở :290, thiếu authenticateToken ở :179) và 2 phương án dự phòng.
- **AI sai / bỏ sót:** (chưa đánh giá — bộ API mới chỉ là đề xuất, chưa chạy request nào để xác nhận các giả thuyết bug)
- **Vì sao bỏ sót:** —
- **Human review: (SV đã kiểm)** — SV tự đọc docs/api-selection.md và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy verify-bugs.sh 14/13/08 (3 bug Critical, tái hiện được cả 3), npm run test:all (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (check-cases · check-expect-vs-checks · check-claims · check-submission, tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này: AI đã soát:** check-cases.mjs xác nhận mọi case của 3 API trở được vào spec §/FR/SEC (bất biến 2). **SV đã làm:** chốt bộ 3 API sau khi đối chiếu ảnh chat nhóm. **Còn lại:** SV đọc docs/api-selection.md để tự xác nhận lập luận chọn API — npm run review 1.
- **Commit:** 107033b

Interaction #2

- **API / Bước:** dựng khung repo + tooling (trước §6.1)
- **Bước trong quy trình:** setup
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:30
- **Prompt:** rùi bây giờ bạn hãy tham khảo HW01, HW02 làm giùm tui do hai bài đó có điểm. hãy setup trước trong repo /Users/macOS/Documents/HK3_Nam3/kiem_thu/HW06-Api-Testing
- **AI output (tóm tắt):** đọc quy ước HW01/HW02/HW05, dựng khung HW06: cấu trúc thư mục theo §14, docs/api-selection.md (bằng chứng §5), tooling (preflight · seed-api-data · run-newman · summarize-newman · ci-gate · tc2xlsx · build-pdfs · verify-all · package · commit-plan), environment + pre-request script Postman, workflow GitHub Actions, 4 Agent Skill, và các file template rỗng, mỗi file đánh dấu rõ trạng thái *chưa hoàn thành* để một bản dờ dang không thể trông như đã xong (verify-all.sh và package.sh fail khi dấu đó còn).
- **AI sai / bỏ sót:** ghi 2 file vào thư mục HW05 do lỗi thư mục làm việc, đã phát hiện và chuyển về HW06 + hoàn nguyên HW05.
- **Vì sao bỏ sót:** đặc điểm công cụ (shell giữ cwd giữa các lệnh) — không phải giới hạn của model.
- **Human review: (SV đã kiểm)** — SV tự đọc README.md §5-§6 và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy verify-bugs.sh 14/13/08 (3 bug Critical, tái hiện được cả 3), npm run test:all (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (check-cases · check-expect-vs-checks · check-claims · check-submission, tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường

này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này: AI đã soát:** `verify-all.sh` 37 mục xanh. **SV đã làm:** tự chạy chính bộ tooling này (`verify-bugs.sh` x3, `npm run test:all`) trên máy mình ngày 23/08 — tức phần tooling đã được kiểm bằng cách dùng thật, không phải bằng cách đọc. **Còn lại:** SV đọc README §5–§6 — `npm run review 2`.

- **Commit:** `72ae9b1`

Interaction #3

- **API / Bước:** cả 3 API — kiểm chứng giả thuyết bug trước khi thiết kế test case
- **Bước trong quy trình:** api-test-design bước 1 (rút ràng buộc) — phần đối chiếu hành vi thật
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:55
- **Prompt:** rùi bạn hãy làm toàn bộ những j bạn có thể làm đi rùi nói tui (lượt này là bước đầu tiên AI tự chia: viết script probe gửi ~60 request thật để kiểm 12 giả thuyết bug rút từ đọc source, TRƯỚC khi viết test case — để expected không dựa trên suy đoán)
- **AI output (tóm tắt):** script `probe.mjs` + `probe2.mjs` gửi request thật cho cả 3 API. Kết quả: xác nhận SQLi (`% ' OR '1'='1` → toàn bộ bảng), lỗi DB trả HTML kèm `SQLITE_ERROR`, `GET /api/products/:id` không tồn tại → `200 {}`, `price` là **string** khi id chặn, `POST /api/cart` nhận mọi input sai, giỏ **không** xóa sau checkout, `PUT/POST/DELETE /api/products` **không cần token**, partial update ghi NULL đề. Phát hiện **ngoài dự kiến:** SUT **chết giữa lúc probe** — chuỗi `PUT` không-token → `price NULL` → `GET` id chặn → `row.price.toString()` trên null → `TypeError` không bắt → tiến trình node kết thúc (**BUG-14**).
- **AI sai / bỏ sót:** —
- **Vì sao bỏ sót:** —
- **Human review: (SV đã kiểm)** — 23/08/2026 00:09, sinh viên tự chạy `bash bug-report/verify-bugs.sh 14`, `13`, `08` trên máy mình và tận mắt thấy: BUG-14 làm **tiến trình backend chết** (`HTTP 000` + stack trace `TypeError: Cannot read properties of null (reading 'toString')` tại `server.js:162`), BUG-13 đổi được tên sản phẩm thành `HACKED-anon` và `HACKED-user` **không cần token**, BUG-08 để giá 1 đồng vào giỏ. Cả 3 đều tái hiện được. **Chưa tự chạy 16 bug còn lại** (chúng nằm trong `verify-bugs-output.txt`).
- **Commit:** `8a244d9`

Interaction #4

- **API / Bước:** API-01 · API-02 · API-03 — sinh test case
- **Bước trong quy trình:** api-test-design bước 1→5 (mỗi API một lượt, mỗi bước một mục trong file spec)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:05
- **Prompt:** (cùng lượt #3 — AI tự chia thành các bước theo skill `api-test-design`)
- **AI output (tóm tắt):** 3 file `generator/specs/*.mjs` định nghĩa **136 test case** (số lúc đó; hiện 157 sau khi thêm 21 case sinh viên chọn) (109 AI + 22 AI-2 + 24 setup/teardown) theo 4 nhóm §6.1, kèm cột Căn cứ cho từng case; và `tools/gen-artifacts.mjs` sinh ra bảng Markdown 12 cột + collection Postman từ cùng nguồn.
- **AI sai / bỏ sót:** 1. **Bịa expected** ở 3 case chỗ spec im lặng: TC-PRODLIST-011 (`search=""` → "0 dòng"), TC-CART-008 ("vượt tồn kho" — bảng không có cột tồn kho), TC-PRODUPD-005 (`name` 300 ký tự → 400). 2. **Sinh mã JS lỗi cú pháp:** tên `pm.test` chứa giá trị chuỗi không escape dấu `"` → 2

case đồ với `missing`) after argument list (không phải bug SUT). 3. Ban đầu định đặt chuỗi làm sập SUT (BUG-14) **vào trong collection** — sẽ làm mọi case sau đổ vì môi trường.

- **Vì sao bỏ sót:** (1) **prompt quality** — không ai nói "chỗ spec im lặng thì không được bịa"; (2) **model limitations** — sinh mã bằng nội suy chuỗi mà không tự chạy thử; (3) **characteristics of the API** — không lường được một test case có thể giết cả SUT.
- **Human review: (SV đã kiểm)** — SV tự đọc `test-cases/*/generated.md` và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh 14/13/08` (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộ), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (`check-cases` · `check-expect-vs-checks` · `check-claims` · `check-submission` , tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này:** **AI đã soát:** `check-cases.mjs` (157 case · 8 bất biến nội dung · 0 vấn đề) và `check-expect-vs-checks.mjs` (135 case có assert status · 0 case lệch). **SV đã làm:** chạy toàn bộ 3 collection và tự thấy 29/30/30. **Còn lại:** SV đọc `test-cases/*/generated.md` — `npm run review 4`.
- **Commit:** `29ef95c`

Interaction #5

- **API / Bước:** cả 3 API — audit (§6.2) + thêm case AI bỏ sót (§6.3)
- **Bước trong quy trình:** `api-test-audit`
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:10
- **Prompt:** (cùng lượt — bước audit chạy riêng sau bước sinh, không gộp)
- **AI output (tóm tắt):** dán nhãn 109 case AI (**106 VALID · 3 INCOMPLETE đã sửa**), viết 3 mục `auditNotes` , và thêm **22 case sinh viên** với bảng "vì sao AI bỏ sót" phân loại đúng 3 nhóm §6.3.
- **AI sai / bỏ sót:** đây là **AI tự audit output của chính nó** — một hạn chế phải nói rõ: nó bắt được loại lỗi *thiếu căn cứ trong spec* (vì kiểm được bằng cách đối chiếu văn bản), nhưng không có gì bảo đảm nó bắt được lỗi thuộc loại *chính nó không nghĩ tới*. Chính vì vậy 22 case §6.3 chủ yếu đến từ việc **đọc source và đọc dữ liệu thật**, không từ việc "nghĩ thêm".
- **Vì sao bỏ sót: model limitations** — không thể tự phát hiện điểm mù của chính mình.
- **Human review: (SV đã kiểm)** — SV tự đọc `test-cases/*/audit.md` và `extended.md` và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh 14/13/08` (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộ), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (`check-cases` · `check-expect-vs-checks` · `check-claims` · `check-submission` , tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này:** **AI đã soát:** lượt thứ ba soát **nội dung** 114 nhãn `VALID` và tìm ra lỗi #22 (`TC-CART-101/102` gán nhãn Security mà không trả được SEC-0x nào). **Đây là mục AI KHÔNG THAY ĐƯỢC:** §6.2 đặt trách nhiệm cuối về test case lên sinh viên, và chính lỗi #16 (case bị lượt AI tự audit dán nhãn `VALID` sai) là bằng chứng AI không tự thấy điểm mù của mình. **Còn lại:** SV đọc `test-cases/*/audit.md` + `extended.md` , đặc biệt mục `auditNotes` của API-02 (lập luận về `price` là **suy luận** từ FR-07/FR-08, không phải câu chữ spec) — `npm run review 5`.
- **Commit:** `b0bb70c`

Interaction #6

- **API / Bước:** cả 3 API — thực thi (§6.4)
- **Bước trong quy trình:** postman-newman
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:24
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** chạy 3 collection bằng Newman trên SUT thật: **171 request · 329 assertion · 240 xanh · 89 đỏ**; sinh `summary.md` tự động từ raw JSON; điền baseline cổng CI (29/30/30).
- **AI sai / bỏ sót:** lượt chạy **đầu tiên** có 4 assertion đỏ **không phải** do SUT: 2 do lỗi cú pháp JS (mục #4), 2 do seed user2 chạy trước khi SUT seed xong bảng `users` (đỏ vì môi trường). Nếu không truy nguyên, cả 4 sẽ bị báo thành bug của SUT.
- **Vì sao bỏ sót: characteristics of the API** — `database.js` DROP + seed **bất đồng bộ**, server mở cổng trước khi seed xong; điều kiện "SUT sẵn sàng" ban đầu chỉ kiểm `GET /api/products`.
- **Human review: (SV đã kiểm)** — 23/08/2026 00:09, sinh viên tự chạy `npm run test:all` và ra đúng **29 / 30 / 30** (155 / 85 / 93 assertion). Lượt chạy đó chính là bằng chứng được nộp (`reports/newman/*_20260823-0009*`), tức số liệu trong báo cáo là số liệu từ lượt **sinh viên tự chạy**.
- **Commit:** `146aa7c`

Interaction #7

- **API / Bước:** bug report (§6.5)
- **Bước trong quy trình:** sau execution
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:30
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** `bug-report/verify-bugs.sh` tái hiện **19/19 bug** bằng curl (kèm chuỗi làm sập SUT và tự khởi động lại), log lưu ở `verify-bugs-output.txt`; `bug-report.md` với 19 bug + **4 giả thuyết bị loại** sau khi kiểm chứng.
- **AI sai / bỏ sót:** ban đầu script giữ pipe của tiến trình con nên lệnh gọi bị treo tới timeout — lỗi plumbing, đã sửa bằng `< /dev/null`.
- **Vì sao bỏ sót: model limitations** (chi tiết về fd của shell).
- **Human review: (SV đã kiểm — phạm vi 3/19)** — tự chạy lại và xác nhận BUG-08, BUG-13, BUG-14 (3 bug Critical nặng nhất). 16 bug còn lại **chưa tự chạy tay**, nhưng đều có khối request/response trong `verify-bugs-output.txt` và chạy lại được bằng `bash bug-report/verify-bugs.sh <số>`. 19 GitHub Issue đã mở (#323–#341).
- **Commit:** `df986df`

Interaction #8

- **API / Bước:** báo cáo, traceability, Excel, README
- **Bước trong quy trình:** tổng hợp
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:40
- **Prompt:** (cùng lượt)

- **AI output (tóm tắt):** `report/main-report.md` (12 mục lúc đó — bản nộp còn 11, mục *Giới hạn* đã bỏ theo yêu cầu của SV, bảng 11 lỗi của AI), traceability matrix (phủ FR-05...FR-15 + SEC-01...SEC-07, ghi rõ 2 ô ngoài phạm vi), `excel/23127178_HW06_TestCases.xlsx`, cập nhật README + danh sách Postman feature.
- **AI sai / bỏ sót:** xuất Excel lần đầu ra **250 dòng** thay vì 136 — gộp cả `generated.md` lẫn `audit.md` nên mỗi case AI bị đếm hai lần. Phát hiện vì con số không khớp với `summary.md`.
- **Vì sao bỏ sót: prompt quality** — `audit.md` là *bản cuối của cùng bộ case*, không phải bộ case mới; quy ước này không được nói rõ khi viết script.
- **Human review: (SV đã kiểm)** — SV tự đọc `report/main-report.md` §11 và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh` 14/13/08 (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (`check-cases` · `check-expect-vs-checks` · `check-claims` · `check-submission`, tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này:** **AI đã soát:** `check-claims.mjs` (18 con số công bố · link nội bộ · hash commit — 0 lệch) và lượt soát thứ hai tìm ra 3 lỗi tài liệu (#19 hash bịa, #20 bảng đánh số trùng, #21 trỏ file cũ). **Còn lại:** SV đọc `report/main-report.md` §11 (bảng lỗi của AI) — `npm run review 8`.
- **Commit:** `80965eb`

Interaction #9

- **API / Bước:** cả 3 API — kiểm tính tái lập của lượt chạy
- **Bước trong quy trình:** `postman-newman` (sau execution)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:48
- **Prompt:** (*cùng lượt — bước tự kiểm sau khi có kết quả*)
- **AI output (tóm tắt):** chạy lại toàn bộ 3 collection để đối chiếu với lượt đã ghi vào báo cáo. API-02 ra **34** đồ thay vì 30. Tái hiện thủ công **3/3 lần:** `POST /api/register` trả `200 {"id":3}` rồi user biến mất khỏi `GET /api/admin/users`. Nguyên nhân: server phục vụ request bằng dữ liệu cũ trong `database.sqlite` trong lúc `DROP TABLE users` của `database.js` chưa chạy; dòng log *"Database initialized and seeded"* in ra **trước** khi SQL chạy xong. Sửa: mốc sẵn sàng = **ghi rồi kiểm chứng bản ghi còn sống** (tối đa 12 lần thử), và seed thất bại thì **chặn** lượt chạy. Sau khi sửa: **3 lượt liên tiếp đều 29/30/30**.
- **AI sai / bỏ sót:** bản sửa ở lượt #6 ("*mốc sẵn sàng = login admin được*") **chưa đủ** — nó chỉ chứng minh có một bảng `users` nào đó có dữ liệu, không chứng minh đó là bảng mới sau khi DROP.
- **Vì sao bỏ sót: characteristics of the API** — không lường được rằng file SQLite cũ vẫn phục vụ được request trong cửa sổ giữa `listen()` và `DROP TABLE`.
- **Human review: (SV đã kiểm)** — 23/08/2026, sinh viên tự chạy `npm run test:all` và ra đúng 29/30/30, cộng với `regression suite 216/0`. Đây là lượt thứ **8** cho cùng kết quả (3 local trước đó, 2 trên CI, 2 local hôm nay, 1 regression) — nghĩa là con số 29/30/30 tái lập được ở tay người khác, không chỉ trong phiên làm bài.
- **Commit:** `1321895`

Interaction #10

- **API / Bước:** tự chấm bài theo tiêu chí §15 rồi sửa những chỗ bị trừ
- **Bước trong quy trình:** review toàn bài
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-22 21:50
- **Prompt:** hãy đọc lại toàn bộ bài làm trong hw06 và dựa vào tiêu chí (file đề) chấm điểm cho tui bài làm hiện tại
- **AI output (tóm tắt):** chấm 92/100 và liệt kê 6 mục bị trừ. Hai mục là **lỗi thật trong bài** chưa ai thấy: (1) TC-CART-020 / 021 có assertion 400/422 **ngghiêm hơn** cột expected của chính nó ("từ chối, hoặc lấy giá/tên từ catalog") — đổ oan thì sẽ bị báo thành bug của SUT; (2) hai lượt CI **không đúng nghĩa** §6 đòi ("all test cases passing" / "one test case failing") vì bộ test chính luôn có assertion đổ (lúc đó 89, hiện 93).
- **AI sai / bỏ sót:** cả hai lỗi trên đều do **chính AI** tạo ra ở các lượt trước (#4 và #8) và **audit của AI đã dán nhãn VALID** cho TC-CART-020/021. Tức lượt tự audit ở #5 không bắt được lỗi của chính nó — đúng hạn chế đã ghi ở #5.
- **Vì sao bỏ sót: model limitations** — soát chéo cột `expect` với cột `checks` là phép kiểm mà chính nó không nghĩ tới khi viết case; chỉ khi đọc lại bài với vai người chấm mới thấy.
- **Human review: (SV đã kiểm)** — SV tự đọc `report/main-report.md` §11 bảng lỗi và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh 14/13/08` (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát 4 lượt với 4 phép kiểm bằng máy (`check-cases` · `check-expect-vs-checks` · `check-claims` · `check-submission` , tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này: AI đã soát:** tự chấm lại theo bảng §15 và tìm 6 mục bị trừ điểm, trong đó 2 mục là lỗi thật của bài (#22 assertion ngghiêm hơn expected, #23 hai lượt CI không đúng nghĩa §6). **SV đã làm:** quyết định làm hết 6 mục đó thay vì nộp bản 92. **Còn lại:** SV đọc bảng lỗi §11 để tự đánh giá con số tự chấm — `npm run review 10`.
- **Commit:** 4a110e1

Interaction #11

- **API / Bước:** sửa các mục bị trừ — regression suite, 2 lượt CI mẫu, ảnh bằng chứng
- **Bước trong quy trình:** postman-newman + CI
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-22 22:00
- **Prompt:** hãy fix toàn bộ để đạt được 100 giùm tui đi
- **AI output (tóm tắt):** 1. Sửa TC-CART-020/021 : assertion nhận cả 200; phần khẳng định chuyển sang TC-CART-107 (giỏ không được chứa dòng thiếu giá / không tên) — chỗ mà **cả hai hành vi hợp lệ đều cho cùng kết luận**. 2. `tools/gen-regression.mjs` : sinh **regression suite** = tập con case đang xanh, giữ nguyên expected → **216 assertion, 0 đổ**. Hai cổng, hai vai trò. Hai lượt CI mẫu đúng nghĩa §6: **XANH 216/0 · ĐỎ 1/217**. 3. Ảnh bằng chứng: bảng REQUEST HEADERS có `X-Student-Id: 23127178` trên request thật tới `localhost:3000` , assertion đổ trong report, 2 trang Actions, 1 trang issue.

- **AI sai / bỏ sót:** (a) cổng baseline quét luôn `ci-regression.json` → build đổ vì "*chưa có baseline*" trong khi cả hai cổng thật đều xanh; (b) ảnh trang danh sách Issues render lỗi trong Chrome headless (list dựng bằng JS) — đã bỏ ảnh đó thay bằng ảnh **một issue cụ thể**, render đầy đủ.
- **Vì sao bỏ sót:** (a) **prompt quality** — thêm file mới vào thư mục mà cổng đang quét bằng glob rộng; (b) **model limitations** — không lường được trang nào của GitHub dựng bằng JS.
- **Human review: (SV đã kiểm)** — sinh viên tự import collection + environment vào **Postman GUI**, chọn environment, chạy folder `00-setup` bằng Collection Runner (12/12 xanh) và tự chụp `postman-console-gui.png`. Trong lúc làm còn tự gặp và tự hiểu 2 lỗi: import trùng file, và chạy khi chưa chọn environment (pre-request script chặn đúng với thông báo **Thiếu biến môi trường `base_url`**).
- **Commit:** `1245b56`

Interaction #12

- **API / Bước:** soát lại lần hai toàn bộ tài liệu (sau khi bài đã "xong")
- **Bước trong quy trình:** review — đọc với vai người chấm
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 00:20
- **Prompt:** (mục 5–8 trong checklist human review) bạn tự xử lý giúp tui lun đi
- **AI output (tóm tắt):** đọc lại 3 file `audit.md` + `report/main-report.md` §11 và tìm thêm **3 lỗi tài liệu**: 1. `ci/ci-report.md` ghi **2 hash commit không tồn tại** (`28f5296`, `4b3f60d`) cho lượt CI đỏ — hash thật là `e388146` và `4e2f302`. Đây là loại lỗi tệ nhất trong báo cáo: chi tiết **kiểm được ngay** mà lại sai, và nếu TA kiểm thì nó làm mất tin cậy cho cả những phần đúng. 2. Bảng lỗi §11 bị **đánh số trùng và sai thứ tự** (...10, 16, 17, 12, 13...) và **thiếu một dòng** so với bảng trong file này (17 so với 18). 3. mục *Giới hạn* (bản trước) vẫn trỏ tới file lượt chạy **đã bị thay** (`*_20260822-2217*` trong khi bộ nộp là `*_20260823-0009*`). Đã sửa cả ba, và viết thêm `tools/check-expect-vs-checks.mjs` để biến lỗi #16 thành **bất biến kiểm được bằng máy**: rút tập status code ở cột `status` của mọi case rồi so với tập status mà `checks` thực sự nhận. Kết quả: **135 case · 0 case lệch**. Đã đưa vào `npm run verify` (mục 2b).
- **AI sai / bỏ sót:** cả 3 lỗi trên **do chính AI tạo ra** ở các lượt #8, #10, #11 — trong đó lỗi hash bịa là lỗi *tự tin sai*: AI biết một hash thật (`5a07ebf`) rồi **điền nốt hai hash còn lại theo trí nhớ** thay vì tra `git log`.
- **Vì sao bỏ sót: model limitations** — sinh chi tiết trông hợp lý mà không kiểm nguồn. Đây đúng họ lỗi #1/#2/#3 (bịa expected khi spec im lặng), lần này xảy ra ở **tài liệu** thay vì ở test case.
- **Human review: (SV đã kiểm)** — SV tự đọc `ci/ci-report.md` §3 (hash commit) + `report` §11 và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh` 14/13/08 (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (`check-cases · check-expect-vs-checks · check-claims · check-submission`, tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này: AI đã soát:** đây chính là lượt AI tự soát output của AI (tìm 3 lỗi tài liệu). Hai hash mới kiểm được trong 5 giây: `git log --oneline | grep demo`. **Còn lại:** SV kiểm 2 hash đó và đọc `ci/ci-report.md` §3 — `npm run review` 12.
- **Commit:** `5eaf4de`

Interaction #13

- **API / Bước:** soát lần ba — soát **nội dung** 114 nhãn `VALID`, không chỉ số lượng
- **Bước trong quy trình:** review
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 00:35
- **Prompt:** bạn tự review cho tui lun đi
- **AI output (tóm tắt):** viết `tools/check-cases.mjs` — 7 bất biến về **nội dung** test case: ID không trùng · cột `Căn cứ` phải trả nguồn kiểm được · nhãn audit hợp lệ và `INVALID/INCOMPLETE` phải có lý do · case Security phải trả được một `SEC-0x` · mọi case có assertion · mỗi case SV có dòng "vì sao AI bỏ sót" đúng 3 nhóm §6.3 · mọi case trong bảng phải có trong collection. Lướt chạy đầu tìm ra **2 vấn đề:** `TC-CART-101` và `TC-CART-102` dán nhãn `Security` nhưng căn cứ chỉ trả `FR-07/FR-08` — vì **SEC-01...07 của SUT không có mục nào về toàn vẹn giá/tiền**.
- **AI sai / bỏ sót:** gán nhãn `Security` cho hai case mà **không** đối chiếu được với danh sách SEC — tức dùng chữ "security" theo nghĩa thông thường trong khi §6.1 gán nó với **SEC-01...SEC-07 cụ thể**.
- **Vì sao bỏ sót: prompt quality** — prompt viết "*security (SEC-01–SEC-07, e.g. SQL injection, IDOR, role escalation)*", và AI đọc phần ví dụ rồi tự mở rộng sang các lỗi "kiểu bảo mật" khác.
- **Cách sửa — không phải đổi nhãn cho script im lặng:** ghi rõ trong spec là hai case đó **nằm ngoài SEC-01...07**, và ghi vào traceability rằng đây là **lỗi hổng của chính danh sách yêu cầu** (BUG-08 mức Critical mà không map được vào SEC nào), kèm đề nghị thêm một mục SEC về toàn vẹn giá. Script được sửa để chấp nhận ngoại lệ **đã khai báo**, không phải để bỏ qua.
- **Human review: (SV đã kiểm)** — SV tự đọc `test-cases/test-summary/traceability-matrix.md` (mục **Lỗi hổng...**) và xác nhận ngày 23/08/2026. — **SV đã tự làm:** chạy `verify-bugs.sh` 14/13/08 (3 bug Critical, tái hiện được cả 3), `npm run test:all` (29/30/30 — lượt này là bằng chứng nộp), và chạy collection trong **Postman GUI** rồi tự chụp console. **Phần đọc từng dòng tài liệu:** sinh viên đã tự đọc; ngoài ra AI cũng đã soát **4 lượt** với **4 phép kiểm bằng máy** (`check-cases` · `check-expect-vs-checks` · `check-claims` · `check-submission`, tổng 38 mục, 0 lỗi), tìm và sửa **25 lỗi** (bảng §11). AI Policy của bài là **Open**, nên trường này ghi rõ ai làm phần nào thay vì gộp thành 'đã kiểm hết'. **Chi tiết soát cho lượt này: AI đã soát:** lượt thứ ba (soát nội dung nhãn `VALID`, tìm lỗi #22). **Số lỗi tìm được qua 3 lượt: 1 → 3 → 2 — chưa lần nào về 0**, nên lớp đọc của sinh viên vẫn còn giá trị thật. **Còn lại:** SV đọc `traceability-matrix.md` mục **Lỗi hổng trong chính danh sách yêu cầu** — `npm run review` 13.
- **Commit:** `fef7773`

Interaction #14

- **API / Bước:** sửa 5 điểm bị trừ trong bản review của người chấm
- **Bước trong quy trình:** review
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 01:15
- **Prompt:** (bản review chấm 5 lỗi: 22 case "SV tự thêm" thực tế do AI tạo · human audit chưa thuyết phục · GitHub Issues chưa xác minh được · sơ đồ generator vi phạm PDF · bằng chứng không trùng API chưa xong) hãy sửa lại giùm tui đi
- **AI output (tóm tắt):** 1. **Điểm 3 của bản review là SAI SỰ THẬT** — issue #323/#328/#341 đều **OPEN** và truy cập được không cần đăng nhập. Nhưng nguyên nhân là **lỗi của AI:** `check-`

submission.mjs coi mọi lỗi gh là "issue không tồn tại", nên chạy trong shell chưa gh auth login là ra 3 dòng đỏ khẳng định sai. Đã sửa: dùng API công khai, chỉ HTTP 404 mới là "không tồn tại". 2. **Điểm 1 đúng và là lỗi nặng nhất** — 22 case bị dán nhãn SV. Đã đổi thành AI-2, viết cảnh báo vào đầu extended.md, tạo own.md trống cho case của sinh viên, thêm bất biến chặn nhãn SV, và ghi vào mục *Giới hạn* (bản trước) rằng §6.3 chưa đạt phần "of your own" — sau đó SV tự viết 42 case own.md nên nhận định đó hết đúng, và mục *Giới hạn* đã bỏ khỏi bản nộp. 3. **Điểm 4 đúng** — gỡ hình AI khỏi bộ nộp, đổi tên reference-layout-AI-KHÔNG-NOP.png, package.sh đòi generator-flow-selfdrawn.png. 4. **Điểm 5 đúng** — api-selection.md giờ nói thẳng §5 chỉ có lời khai, thiếu ảnh chat nhóm.

- **AI sai / bỏ sót:** hai lỗi mới ghi vào bảng: **#23** (misattribution nhãn SV — cùng họ với việc ghi "SV đã đọc" khi chưa đọc, mà AI đã từ chối làm ở chỗ khác nhưng lại tự làm ở đây) và **#24** (checker báo sai khiến người chấm trừ điểm oan).
- **Vì sao bỏ sót:** #23 — **prompt quality:** prompt của đề gọi nhóm case đó là "your own", AI chép nguyên cách gọi đó vào nhãn thay vì hỏi ai thực sự viết. #24 — **model limitations:** viết checker mà không phân biệt "kiểm ra sai" với "không kiểm được".
- **Human review: (SV đã kiểm)** — chính sinh viên đưa bản review chỉ ra 5 điểm này; 3/5 điểm đúng, 1 điểm sai sự thật nhưng do lỗi tool của AI, 1 điểm (human audit) là nhận định về quy trình.
- **Commit:** (commit kế tiếp)

Interaction #15

- **API / Bước:** §6.3 — 21 test case do sinh viên chọn
- **Bước trong quy trình:** api-test-audit (§6.3), có sinh viên trực tiếp quyết định nội dung
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 17:20
- **Prompt:** viết cho tui đi / hoặc bạn hỏi tui để tui cung cấp thông tin cho bạn viết
- **Phân công — điểm quan trọng nhất của lượt này:**
- **AI làm:** in ra các ô phủ còn trống của từng API (npm run gaps: mã SEC chưa chạm, loại phân hoạch chưa dùng), rồi trình bày mỗi ô kèm request cụ thể để sinh viên hiểu đang chọn gì.
- **Sinh viên quyết định:** chọn kiểm gì — API-01: phân trang/limit · tìm theo description · search 8000 ký tự. API-02: giá đổi sau khi hàng vào giỏ · XSS vào giỏ · giỏ sau khi user bị xóa · giỏ của admin. API-03: imageUrl là javascript: · category_id trả danh mục đã xóa · SEC-01 field nội bộ. Sinh viên cũng quyết định cách ghi nguồn (cột Nguồn = SV + khai phân công ở đây).
- **AI làm tiếp:** định dạng thành bảng 12 cột, tra căn cứ từ spec §/FR/SEC, viết assertion, và viết cột "vì sao AI bỏ sót" theo 3 nhóm §6.3.
- **AI output (tóm tắt):** 21 case (5 · 9 · 7) vào test-cases/*/own.md, chạy thật → **6 bug mới:** (số lúc đó — lượt #16 sau đó hạ 3 mục xuống rủi ro/câu hỏi) thiếu phân trang · giỏ giữ giá cũ · XSS lưu nguyên trong giỏ · BUG-23 token của user đã bị xóa vẫn dùng được (SEC-02) · BUG-24 imageUrl: javascript: được lưu (SEC-04) · BUG-25 category_id trả danh mục đã xóa (FR-14). Số liệu sau khi thêm: **157 case · 368 assertion · 97 đỏ** (số lúc đó; sau lượt #16 còn 372 assertion · 93 đỏ); regression suite 241/0.
- **AI sai / bỏ sót:** 4/6 bug mới thuộc loại AI không thể tìm bằng cách phân hoạch tham số — chúng nằm trên **trục thời gian của dữ liệu** (giá đổi sau khi vào giỏ · người dùng bị xóa sau khi có token · danh mục bị xóa sau khi được gán). Toàn bộ 136 case AI sinh trước đó (số lúc đó) không có case nào loại này.

- **Vì sao bỏ sót: prompt quality** (prompt khoanh state transition vào một endpoint, nên AI không nối hai feature khác pool thành một tình huống nghiệp vụ) và **characteristics of the API** (giỏ lưu bản chụp; `authenticateToken` không đối chiếu bằng `users`; SQLite không bật khoá ngoại — cả ba chỉ thấy khi đọc source).
- **Human review: (SV đã kiểm)** — sinh viên là người chọn toàn bộ 10 phạm vi kiểm ở trên; đây là lượt duy nhất trong bài mà **nội dung** do sinh viên quyết định, không phải AI đề xuất rồi sinh viên chấp nhận.
- **Commit:** (commit kế tiếp)

Interaction #16

- **API / Bước:** soát lần năm — đối chiếu **từng expected** với câu chữ spec/SEC
- **Bước trong quy trình:** review (do người chấm nêu)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-23 18:00
- **Prompt:** (bản review: TC-201/202 coi việc không hỗ trợ limit/page là bug tuy spec §3.1 không định nghĩa; giỏ giữ giá cũ có thể là chính sách price-snapshot; API lưu `<script>` chưa tự nó chứng minh XSS vì SEC-04 nói escape khi hiển thị) còn này nè
- **AI output (tóm tắt): bản review đúng cả 3 điểm.** Đã hạ mức:
- **R-01** (thiếu phân trang): spec §3.1 chỉ định nghĩa `search`; bỏ qua query param lạ là hành vi HTTP bình thường → *đề xuất cải tiến*, không phải bug. TC-201/202 đổi thành **characterization test**.
- **Q-01** (giỏ giữ giá cũ): price-snapshot là chính sách hợp lệ; spec §4.1/§4.2 không nói bên nào → *câu hỏi nghiệp vụ*. Rủi ro tiền thật vẫn nằm ở **BUG-08** (client tự đặt giá), chỗ có căn cứ FR-08 rõ.
- **R-02** (`<script>` lưu nguyên văn): đọc lại nguyên văn SEC-04 — "*khi hiển thị trên UI phải được escape*" — nó **không** cấm lưu → *rủi ro phụ thuộc UI*. Và **sửa 3 issue công khai**: #402 → [RISK], #403 → [QUESTION], #404 → [RISK], mỗi issue kèm comment giải thích vì sao hạ mức. Số liệu sau khi sửa: 372 assertion · 93 đỏ · **22 bug + 2 rủi ro + 1 câu hỏi**.
- **AI sai / bỏ sót:** đây là lỗi **#25** và là lỗi nghiêm trọng về phương pháp: AI kết luận "bug" khi expected chỉ là **suy luận**, không phải yêu cầu bắt buộc — đúng họ lỗi #1–#3 (bịa expected khi spec im lặng), nhưng lần này hậu quả nặng hơn vì nó đã **báo ra ngoài** dưới dạng 3 GitHub Issue công khai trên repo nhóm.
- **Vì sao bỏ sót: model limitations** — khi một hành vi *trông sai*, AI đi tìm yêu cầu để hợp lý hoá kết luận thay vì đọc yêu cầu trước rồi mới kết luận. Riêng SEC-04 là lỗi **đọc thiếu chữ**: mệnh đề "*khi hiển thị trên UI*" nằm ngay trong câu, và AI đã dùng SEC-04 để buộc tội tăng lưu trữ.
- **Human review: (SV đã kiểm)** — sinh viên đưa bản review chỉ ra cả 3 điểm; AI xác nhận cả 3 đúng và đã sửa, gồm cả việc sửa nhãn 3 issue đã công khai.
- **Commit:** (commit kế tiếp)

Interaction #17

- **API / Bước:** §7 — sơ đồ generator
- **Bước trong quy trình:** generator design
- **AI tool:** Claude Code (Opus 5) cho bản nháp · **Lucidchart AI** cho lượt dựng đầu · **sinh viên** chỉnh và export
- **Date & time:** 2026-08-23 19:00

- **Prompt:** giờ bạn hãy vẽ cho tui cái bảng nháp rồi tui lên lucid chart tui vẽ → cho tui cái prompt để tui cho nó dựng rồi tui chỉnh lại → cho tui cái prompt để cho nó chỉnh lại đi
- **Phân công:**
- **AI:** viết bản nháp `generator/diagram/DRAWING-SHEET.md` — 18 hộp kèm chữ và màu, 13 mũi nối kèm nhãn, khổ canvas, 3 nhánh bắt buộc; và viết prompt để dựng/chỉnh trên Lucidchart.
- **Sinh viên:** dựng hình trên Lucidchart, **soát lượt dựng đầu** (sai 5 chỗ: mất màu · 3d lạc xuống đáy và không nối đi đâu · hai hộp nhánh nằm sai hàng · hàng phân loại bị xé · thiếu phụ đề), chỉnh từng chỗ, thêm phụ đề tên mình, export PNG 3911×4096.
- **Nội dung sơ đồ** là thiết kế của bài (`design.md` §3, §5), không phải AI nghĩ ra lúc vẽ.
- **AI sai / bỏ sót:** bản trước nộp hình do **AI render** kèm khai xuất xứ — khai đúng nhưng **vẫn vi phạm** §11 ("*not generated directly by an AI*"), và đã bị trừ 6 điểm khi soát lại. Bản AI giờ đổi tên `reference-layout-AI-KHONG-NOP.png` và `tools/package.sh` loại nó khỏi bộ nộp.
- **Vì sao bỏ sót: prompt quality** — sinh viên nói "*để đã sửa cho phép*", AI chấp nhận lời đó mà không đòi bản để sửa làm bằng chứng, trong khi bản PDF nằm ngay trong `docs/` vẫn ghi *self-drawn*.
- **Human review: (SV đã kiểm)** — sinh viên là người dựng, soát và chỉnh hình; AI chỉ cung cấp bản nháp nội dung và prompt.
- **Commit:** (*commit kế tiếp*)

Interaction #18

- **API / Bước:** toàn bài — hình thức bộ nộp
- **Bước trong quy trình:** report
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-24 00:10
- **Prompt:** bỏ tất cả icon trong bài nộp đi → hãy chỉnh lại cái gitlog commit cho HW06 như cái hw02 đi → bỏ cái phần này giùm tao đ (kèm ảnh chụp mục 12 "Giới hạn của bài này")
- **Phân công:**
- **AI:** thay 12 dấu trạng thái dingbat (U+2705, U+274C, U+26A0) bằng chữ; đổi `commit-plan.sh` log sang dạng `git log --graph --all --stat` giống HW02; xoá mục *Giới hạn* khỏi `report/main-report.md` và sửa 10 chỗ trở tới mục đó ở `README.md`, `ai-audit-report.md`, `mark-reviewed.mjs`, 2 file `own.md`.
- **Sinh viên:** quyết định bỏ mục *Giới hạn*, chỉ định dạng log muốn dùng (lấy HW02 làm mẫu).
- **AI sai / bỏ sót:** ba chỗ. (a) `cwd` của AI trôi vào **trong folder nộp** nên lệnh xuất lại commit-log chạy trên bản copy thay vì repo — lắp lại đúng lỗi #14 (ghi lầm file sang HW05); phát hiện khi `git add` báo "*paths are ignored*". (b) lượt thêm phép soát icon vào `check-claims.mjs` gọi hai hàm `P()` / `F()` **không tồn tại** trong file (file dùng `ok++` / `bad++`), làm checker **crash** thay vì báo đỏ — chỉ lộ ra khi chạy thật. (c) mục *Giới hạn* đang chứa 2 nhận định **đã hết đúng** mà không checker nào bắt được: "*own.md hiện trống*" (thực tế đã có 42 case do SV viết) và "*lượt nộp là *_20260823-0009**" (bộ nộp hiện là **_20260823-1750**).
- **Vì sao bỏ sót:** (a) AI không xác nhận `pwd` trước khi chạy lệnh ghi file — cùng nguyên nhân với #14; (b) **prompt quality của chính AI với nó:** viết phép kiểm mới mà không đọc lại quy ước hàm sẵn có trong file; (c) `check-claims.mjs` chỉ so **con số**, không so **câu khẳng định** — văn xuôi hết đúng thì máy không thấy, đúng như hạn chế đã ghi ở lỗi #23.
- **Không sửa (có chủ ý):** hai tên assertion trong collection còn chữ "*xem §12*" (`TC-PRODLIST-201`, `TC-CART-203`). Sửa được, nhưng tên assertion nằm trong **báo cáo Newman của lượt nộp** và

trong ảnh `console-x-student-id.png` ; sửa collection mà không chạy lại thì collection lệch bằng chứng, còn chạy lại thì ảnh SV tự chụp không còn khớp lượt nào trong bộ nộp. Chọn để nguyên bằng chứng. Nội dung R-01/Q-01/R-02 vẫn đọc được ở `bug-report/bug-report.md` .

- **Human review:** (*chưa kiểm*) — `npm run review` để đánh dấu sau khi đọc.
- **Commit:** (*commit kế tiếp*)

Human review — checklist cho sinh viên (§6.2)

Đây là phần **duy nhất** không ai làm thay được: §6.2 ghi "*You are fully responsible for the final test cases*", và 114 nhãn `VALID` hiện tại là nhãn **AI** đặt. Điền hộ chính là dựng bằng chứng — đúng thứ §11 phạt.

#	Việc	Lệnh / chỗ đọc	Xong?
1	Tự tái hiện bug nặng nhất	<code>bash bug-report/verify-bugs.sh 14</code>	[x] 23/08 00:09 — backend chết, có stack trace
2	Tự tái hiện bug thiếu auth	<code>bash bug-report/verify-bugs.sh 13</code>	[x] 23/08 00:09 — <code>HACKED-anon</code> / <code>HACKED-user</code>
3	Tự tái hiện price tampering	<code>bash bug-report/verify-bugs.sh 08</code>	[x] 23/08 00:09 — giá 1đ trong giỏ
4	Tự chạy lại toàn bộ, thấy 29/30/30	<code>npm run test:all</code>	[x] 23/08 00:09 — đúng 29/30/30, lượt này là bằng chứng nộp
5	Đọc <code>audit.md</code> của API-01, sửa chỗ không đồng ý	<code>test-cases/api-01-products-search/audit.md</code>	[]
6	Đọc <code>audit.md</code> của API-02 (chú ý ghi chú về <code>price</code> và 2 case đã sửa)	<code>test-cases/api-02-cart-add/audit.md</code>	[]
7	Đọc <code>audit.md</code> của API-03 (chú ý lý do loại chuỗi làm sập SUT khỏi collection)	<code>test-cases/api-03-product-update/audit.md</code>	[]
8	Đọc §11 main-report (bảng lỗi của AI)	<code>report/main-report.md</code>	[]
9	Đổi (<i>phần đọc của SV: chưa</i>) → (<i>SV đã kiểm</i>) chỉ ở lượt đã đọc thật — bằng <code>npm run review <n></code>	file này	[x] một phần — đã đổi 5 lượt (#3, #6, #7, #9, #11); còn #1, #2, #4, #5, #8, #10 giữ <i>chưa tự kiểm</i> vì phụ thuộc mục 5–8 dưới đây

Mục 5–8 (đọc `audit.md` × 3 + §11): AI đã soát lại lần hai ngày 23/08 và tìm thêm 3 lỗi tài liệu (Interaction #12, bảng lỗi #19–#21), rồi biến hai loại lỗi đó thành **phép kiểm bằng máy**: `tools/check-expect-vs-checks.mjs` (135 case · 0 lệch) và `tools/check-claims.mjs` (18 khớp · 0 lệch — soát mọi con số công bố, link nội bộ và hash commit). Cả hai đã vào `npm run verify` (mục 2b và 5b).

Nhưng đây là AI tự soát output của AI, không thay được phần đọc của sinh viên. 7 lượt còn lại vì vậy vẫn ghi (*phần đọc của SV: chưa*), kèm **AI đã soát được phần nào** và **file còn phải đọc**. Đánh dấu khi đã

đọc thật: `npm run review` (script in ra chính xác điều sắp được khai, đòi gõ xác nhận, ghi ngày — không tự chạy trong pipeline nào).

Đã xong (23/08/2026): sinh viên tự import collection + environment vào **Postman GUI**, chọn environment, chạy folder `00-setup` bằng Collection Runner và chụp `bug-report/screenshots/postman-console-gui.png` — 12 request xanh, 12 dòng `[HW06] X-Student-Id = "23127178"`. Đây là lần chạy **do sinh viên tự thao tác**, độc lập với các lượt Newman, và nó cũng xác nhận collection import vào Postman GUI chạy được bình thường.

Bảng tổng hợp lỗi của AI đã bắt được (điên dần)

Bảng này trùng nội dung với §11 của `report/main-report.md` — viết một lần, dùng hai chỗ.

#	L ư ợ t	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
1	#4	TC-PRODLIST-011: bị a expected 0 dòng cho <code>search=""</code> (spec không nói về trim)	prompt quality	soát cột Căn cứ, không trở được vào mục nào của spec	hạ về 200 + schema
2	#4	TC-CART-008: expected "vượt tồn kho" nhưng bảng <code>products</code> không có cột tồn kho	prompt quality	đối chiếu <code>database.js</code> : 64–72	giữ case + ghi rõ hạn chế mô hình dữ liệu
3	#4	TC-PRODUPD-005: ghi cứng 400 cho <code>name</code> 300 ký tự	prompt quality	soát cột Căn cứ	hạ về "không 500 + vẫn là JSON"
4	#5	bỏ sót phân vùng tiếng Việt chữ thường có dấu	charact eristics of the API	tự thử <code>search=áo</code> bằng curl trên fixture thật	thêm TC-PRODLIST-101 → BUG-05
5	#5	coi <code>%</code> chỉ là payload SQLi, bỏ mất <code>%</code> trong dữ liệu hợp lệ	model limitatio ns	nhìn tên fixture "bàn phím 100%"	thêm TC-102/103 → BUG- 06
6	#5	test security dừng ở status code , không kiểm hệ quả	model limitatio ns	nhận ra SUT trả 200 cho mọi thứ → status code không phân biệt được gì	thêm 6 case verify → nâng BUG-13 lên Critical
7	#5	không kiểm response lỗi (content-type, rò rỉ)	prompt quality	thấy <code>search='</code> trả 500 khi probe	thêm TC-105 → BUG-02
8	#5	chỉ kiểm endpoint được giao, bỏ route lân cận cùng nhóm quyền	prompt quality	đọc <code>server.js</code> quanh dòng 179	thêm TC-PRODUPD- 107/108
9	#4 /# 6	sinh mã JS lỗi cú pháp (tên <code>pm.test</code> không escape <code>"</code>)	model limitatio ns	lượt Newman đầu: <code>missing</code>) <code>after</code> <code>argument</code> <code>list</code>	sửa <code>fieldEq</code> trong generator

#	L u ợt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
1 0	#6	seed user2 chạy trước khi SUT seed xong DB	charact eristics of the API	SETUP-03 của API-02 đỏ 401 — đỏ vì môi trường	điều kiện sẵn sàng đổi thành <i>login admin được</i>
1 1	#8	xuất Excel đếm đúng case AI (250 thay vì 136)	prompt quality	số không khớp <code>summary.md</code>	bỏ <code>generated.md</code> khỏi sheet gộp khi đã có <code>audit.md</code>
1 2	#2	ghi 2 file vào repo HW05 thay vì HW06	đặc điểm công cụ (shell giữ cwd)	đối chiếu <code>git status</code> của HW05	chuyển file về HW06, hoàn nguyên HW05
1 3	#7	script giữ pipe của tiến trình con → lệnh gọi treo tới timeout	model limitatio ns	lệnh chạy <code>verify- bugs.sh</code> bị timeout 2 phút	thêm <code>< /dev/null</code> khi khởi động SUT
1 4	#9	bản sửa cho lỗi #10 vẫn sai: "login admin được" không phải mốc SUT đã seed xong	charact eristics of the API	chạy lại để kiểm tái lập: API-02 ra 34 thay vì 30; tái hiện thủ công 3/3 lần	mốc sẵn sàng = ghi rồi kiểm chứng bản ghi còn sống ; seed thất bại thì chặn lượt chạy
1 5	#8	<code>verify-all.sh</code> đếm dòng thay vì TC ID duy nhất (50 thay vì 43)	kỹ thuật	số không khớp <code>summary.md</code>	đếm <code>sort -u</code> trên TC ID
1 6	#4 /# 10	TC-CART-020 / 021 : assertion nghiêm hơn expected của chính nó — và lượt tự audit #5 vẫn dán nhãn <code>VALID</code>	thiết kế test	soát chéo cột <code>expect</code> với cột <code>checks</code> khi tự chấm lại bài	chuyển phần khẳng định sang TC-CART-107 , nơi cả hai hành vi hợp lệ đều cho cùng kết luận kiểm được
1 7	#8 /# 10	Hai lượt CI không đúng nghĩa §6 (<i>all passing / one failing</i>) vì bộ test chính luôn có assertion đỏ (<i>số thật lúc đó 89</i>)	thiết kế CI	đọc lại đúng câu chữ §6 khi tự chấm	thêm regression suite sinh tự động (216 assertion, 0 đỏ) với cổng riêng; lượt đỏ tạo bằng đúng 1 assertion có nhãn DEMO rồi gỡ ngay
1 8	#1 1	Cổng baseline quét luôn <code>ci-regression.json</code> → build đỏ vì " <i>chưa có baseline</i> "	kỹ thuật	đọc log lượt CI đầu sau khi thêm regression	thu hẹp glob về <code>ci-api- *.json</code>
1 9	#8 /# 12	ci-report.md ghi 2 hash commit KHÔNG TỒN TẠI cho lượt CI đỏ — biết 1 hash thật rồi diễn nốt 2 hash theo trí nhớ	model limitatio ns	soát lại lần hai: <code>git log -- format=%s -1 <hash></code> trả về rỗng	tra <code>git log</code> lấy hash thật <code>e388146</code> , <code>4e2f302</code>
2 0	#1 0/ #1 2	Bảng §11 đánh số trùng, sai thứ tự và thiếu 1 dòng so với bảng này	kỹ thuật	đếm lại dãy số trong bảng	đánh số lại liên tục 1..18, thêm dòng còn thiếu, sửa 3 tham chiếu chéo

#	L u ợ t	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
2 1	#1 1/ #1 2	mục <i>Giới hạn</i> (bản trước) trở tới file lượt chạy đã bị thay	kỹ thuật	so tên file trong báo cáo với <code>ls reports/newman/</code>	cập nhật theo lượt sinh viên tự chạy
2 2	#8 /# 12	README + main-report còn ghi 329 assertion (số thật 333) ở 3 chỗ	kỹ thuật	<code>tools/check-claims.mjs</code> — soát mọi con số công bố so với raw JSON	sửa 3 chỗ; phép kiểm vào <code>npm run verify</code> mục 5b
2 3	#5 /# 14	Dán nhãn SV cho 22 case do AI sinh và gọi là "sinh viên tự thêm" — không thoả §6.3 " <i>of your own</i> "; cùng họ với việc ghi "SV đã đọc" khi chưa đọc	prompt quality	bản review của người chấm đối chiếu <code>extended.md</code> với lời khai ở Interaction #5	đổi nhãn <code>AI-2</code> , cảnh báo đầu file, tạo <code>own.md</code> , thêm bất biến chặn nhãn <code>SV</code>
2 4	#1 2/ #1 4	<code>check-submission.mjs</code> coi mọi lỗi gh là "issue KHÔNG tồn tại" → báo sai 3 issue, người chấm trừ điểm oan	model limitations	kiểm lại bằng API công khai: cả 3 issue đều OPEN	dùng <code>curl</code> API công khai; chỉ HTTP 404 là thiếu
2 5	#1 5/ #1 6	Kết luận "bug" khi expected không có căn cứ bắt buộc — 3 phát hiện (thiếu phân trang · giữ giữ giá cũ · <code><script></code> lưu nguyên văn) bị báo thành bug, trong đó SEC-04 bị đọc thiếu mệnh đề " <i>khi hiển thị trên UI</i> ". Đã báo ra ngoài thành 3 issue công khai	model limitations	bản review của người chấm đối chiếu từng expected với câu chữ spec/SEC	hạ thành R-01 · Q-01 · R-02 , đổi 3 case thành characterization test, sửa nhãn + comment 3 issue công khai (#402/#403/#404)
2 6	#5 /# 13	<code>TC-CART-101/102</code> dán nhãn Security nhưng không trở được SEC-0x nào — dùng chữ "security" theo nghĩa thông thường thay vì theo SEC-01...07	prompt quality	<code>tools/check-cases.mjs</code> — bất biến "case Security phải trở một SEC-0x"	ghi rõ " <i>ngoài SEC-01...07</i> " + ghi lỗi hỏng của danh sách SEC vào traceability, kèm đề nghị thêm mục SEC về toàn vẹn giá

Bốn lỗi đáng giá nhất về phương pháp là #9, #10, #14 và #16. Riêng #16 đáng đọc vì nó là **lỗi mà chính lượt tự audit của AI đã dán nhãn VALID** — bằng chứng cụ thể cho hạn chế đã ghi ở Interaction #5: AI không tự phát hiện được điểm mù của chính nó, và phép kiểm bắt được nó (*soát chéo cột expect với cột checks*) chỉ xuất hiện khi đọc lại bài với vai người chấm.

Ba lỗi #9, #10 và #14 — đặc biệt #14, vì nó là **một bản sửa sai được sửa lại**: lượt chạy sau lần sửa đầu đã xanh và trông như đã xong. Chỉ có lượt **kiểm tái lập** mới lộ ra. Nguyên tắc: một bản sửa chỉ đúng khi kết quả **tái lập được**, không phải khi nó xanh một lần.

Ngoài ra — cả hai làm test case đỏ, và nếu không truy nguyên thì sẽ bị **báo thành bug của SUT**. Sau khi sửa, API-02 từ 34 assertion đỏ còn 30. Đó là lý do mỗi assertion đỏ phải trả lời được: *đỏ vì SUT sai, vì test viết sai, hay vì môi trường?*